

Test Strategy and Quality Plan

Quality Objectives

The test strategy should prove:

- Tenant isolation is reliable.
- Nomination workflow behaves correctly.
- Fraud and HRBP routing are explainable and recoverable.
- Async events are idempotent.
- Admin and role-based access is enforced.
- Payroll integration failures are handled safely.
- Analytics and observability are trustworthy.
- Deployment changes can be validated and rolled back.

Test Layers

Layer	Scope
Unit tests	Pure validation, feature engineering, formatting, utility behavior.
API tests	FastAPI endpoints, auth dependencies, request/response contracts.
Database tests	Migrations, tenant-scoped queries, schema constraints.
Worker tests	Service Bus payload routing, idempotency, handler outcomes.
Frontend tests	User flows, role-gated tabs, tenant config, form validation.
Integration tests	End-to-end nomination, HRBP, notification, payroll flows.
Security tests	Auth, roles, tenant isolation, impersonation audit, secrets handling.
ML validation	Model training, scoring, thresholds, false positive review.
Observability tests	Logs, traces, KQL, dashboards, alerts.
Performance tests	API latency, queue throughput, analytics query cost.
UAT	Tenant-specific business acceptance.

Critical End-to-End Scenarios

Nomination Happy Path

1. User signs in.
2. Tenant config loads.
3. User submits valid nomination.
4. Nomination status becomes **Submitted**.
5. Integrity worker routes to **Pending**.
6. Manager sees pending approval.
7. Manager approves.
8. Nominator receives outcome email.
9. Payroll broker processes payout if enabled.
10. Status becomes **Paid** after payroll accepted.

Manager Rejection

1. Clean nomination reaches manager queue.
2. Manager rejects with reason.
3. Status becomes **Rejected**.
4. Rejection reason and actor are stored.
5. Nominator receives rejection notification.

HRBP Flagged Path

1. Nomination triggers fraud threshold.
2. Status becomes **PendingHRBPReview**.
3. HRBP users receive alert.
4. HRBP queue displays flags and detail.
5. HRBP approves.
6. Status becomes **Pending**.
7. Manager approval email is sent.

HRBP Rejection Path

1. Nomination triggers fraud threshold.
2. HRBP rejects with reason.
3. Status becomes **Rejected**.
4. Fraud label is saved.
5. Nominator receives HRBP rejection notification.

Description Rejection

1. Description fails semantic or duplicate policy.
2. Status becomes **Rejected**.
3. **nomination.description-rejected** event is published.
4. Nominator receives guidance.

Admin Impersonation

1. Admin selects same-tenant user.
2. Request includes **X-Impersonate-User**.
3. Backend switches effective user.
4. Admin-only access still uses actual user roles.
5. Impersonation action is logged.
6. Cross-tenant impersonation is rejected.

Payroll Failure

1. Approved nomination triggers payroll broker.
2. Provider submission fails.
3. Broker records failure.
4. Broker publishes **payroll.failed**.
5. Auxiliary worker notifies Support users.

6. Nomination remains auditable with reason/status.

API Test Matrix

Area	Tests
Auth	Missing token, invalid token, unknown tenant, unknown user, expired token.
Tenant config	Missing config falls back, invalid JSON fallback, domain injection, categories.
Nominations	Valid create, invalid amount, missing manager, invalid category, short description.
Approvals	Approver only, wrong approver forbidden, reject reason saved, certificate gating.
HRBP	Role required, same-tenant enforcement, approve/reject transitions, pair history.
Admin	Role required, audit logs, model refresh, nomination logs.
Analytics	Tenant scoped outputs, query limits, empty data behavior.
Payroll	PayrollBP required, broker unavailable, employee not found, provider error.
Internal	Missing secret forbidden, valid secret accepted.

Service Bus and Worker Test Matrix

Area	Tests
Publish	Event envelope, application property <code>event_type</code> , trace headers.
Filters	Submitted only to fraud processor, approved only to payroll processor, downstream to email processor.
Idempotency	Duplicate message ID skipped.
Retry	Handler exception abandons message.
Dead-letter	Invalid JSON dead-lettered.
Unknown event	Auxiliary skips unknown event with warning.
Trace	Trace context preserved across message.

ML Validation

Minimum checks:

- Model trains per tenant.
- Model artifact contains expected keys.
- Feature columns match training and inference.
- Tenant-specific amount stats are used.
- Missing model routes safely and logs clearly.
- SHAP explanation does not crash scoring.
- HRBP labels affect future training data.
- Graph job populates findings and snapshots before training.
- Forecast job persists runs and forecast points.

Recommended acceptance metrics:

- Fraud score distribution is not degenerate.
- HRBP false positive proxy is tracked.

- No single feature dominates without review.
- Model performance metrics are recorded with artifact metadata.

Security Test Cases

- User from unregistered Entra tenant is rejected.
- Registered tenant user missing from roster is rejected.
- Standard user cannot access admin analytics.
- Standard user cannot access HRBP queue.
- HRBP cannot access admin analytics unless also admin.
- PayrollBP is required for payroll lookup.
- Admin cannot impersonate another tenant.
- Signed email action token cannot approve wrong nomination/approver.
- Expired email action token is rejected.
- Internal endpoints reject wrong **X-Internal-Key**.

Non-Functional Testing

Performance:

- API P95 latency for common endpoints.
- Analytics query duration.
- Service Bus end-to-end latency from nomination submitted to manager notified.
- Fraud scoring duration.
- Payroll broker response time.

Reliability:

- Worker restart during message processing.
- Duplicate delivery.
- SQL cold start for weekly job.
- Blob model unavailable.
- OpenAI timeout.
- SMTP outage.

Scalability:

- Burst nominations.
- Multiple tenants.
- Large user roster.
- Large graph findings.
- Forecast with longer history window.

Release Gate Checklist

- Frontend build passes.
- Backend import/start passes.
- Alembic migrations reviewed.
- Docker image builds for changed services.

- Critical API smoke tests pass.
- End-to-end nomination flow passes.
- Service Bus workers drain test messages.
- No new high-severity security finding.
- KQL post-deployment validation passes.
- Rollback image tag is known.